

GroAurum

Phase 2 Sprint 2 - Authentication Foundation

Secure multi-role application foundations

Generated: July 16, 2026

Architecture only - no login screens - no Supabase connection

1. Sprint Goal

Convert GroAurum from a UI shell into a secure multi-role application foundation. No new product screens, no UI redesign, no live Supabase Auth. Reusable providers, guards, hooks, RBAC, env config, and error/loading states.

2. Architecture Overview

- packages/auth - framework-agnostic types, RBAC, providers, env parsing
- packages/auth/react - SessionProvider, hooks, ProtectedRoute, RoleGuard, NavigationGuard
- Mock AuthProvider for development; Supabase stub adapter prepared
- Admin ERP wires SessionProvider + route/module guards around existing shell
- Sales/Delivery PWA scaffolds document audience constants for Phase 7

3. Package Folders

```
packages/auth/src/  
  roles.ts permissions.ts types.ts helpers.ts errors.ts env.ts  
  navigation.ts create-auth-provider.ts  
  providers/mock-auth-provider.ts  
  providers/supabase-auth-provider.stub.ts  
  react/ SessionProvider ProtectedRoute RoleGuard  
         NavigationGuard hooks usePermissions AuthStatusViews  
apps/admin-web/src/auth/  
  AdminAuthProviders guards AuthFoundationViews  
  createAdminAuthProvider moduleRoutes
```

4. Roles (RBAC)

- Super Admin
- Operations Manager
- Warehouse Manager
- Sales Manager
- Delivery Manager
- Salesman
- Delivery Executive
- Retail Customer
- Read Only

5. Navigation Audiences

Role group	Destination
Admin roles + Read Only	admin_erp
Salesman	sales_pwa
Delivery Executive	delivery_pwa
Retail Customer	customer_app

6. Providers

- AuthProvider interface - getSession, signIn, signOut, refresh, subscribe
- createMockAuthProvider - in-memory sessions; auto-sign-in in development
- createSupabaseAuthProviderStub - explicit not-connected errors
- createAuthProvider(config) - factory selected by AUTH_PROVIDER env
- SessionProvider - React context wrapping any AuthProvider

7. Guards & Hooks

- ProtectedRoute - requires authenticated session for a given audience
- RoleGuard - module allow-list or explicit roles
- NavigationGuard - detects wrong product surface for the signed-in user
- useSession / useAuthSession - status, session, signIn/signOut
- useCurrentUser - AuthUser | null
- usePermissions - hasPermission, hasRole, canAccessModule

8. Authentication Flow (current)

1. App boots -> parsePublicAuthConfig(env)
2. createAuthProvider({ config }) -> mock | supabase stub
3. SessionProvider subscribes to provider state
4. Mock (dev): autoSignIn as VITE_AUTH MOCK_ROLE (default super_admin)
5. ProtectedRoute waits for status !== loading
6. Authenticated + matching audience -> render AdminShell
7. AdminModuleGuard checks MODULE_ALLOWED_ROLES per route
8. Sidebar filters nav items via usePermissions().canAccessModule

9. RBAC Flow

- Each AdminModule declares MODULE_ALLOWED_ROLES
- Each AppRole declares ROLE_PERMISSIONS capability grants
- Routes wrap pages with AdminModuleGuard(module)
- Settings is super_admin only; Reports open to all admin roles including read_only
- Forbidden foundation view shown when role lacks module access

10. Error & Loading States

- unauthorized - no session
- forbidden - authenticated but role denied
- session_expired - expiresAt passed; provider signed out
- offline - reserved code for network failures
- unexpected - provider/config failures
- Session loading + route loading presentational helpers in @groaurum/auth/react

11. Environment Configuration

```
apps/admin-web/.env.example
VITE_APP_ENV=development|staging|production
VITE_AUTH_PROVIDER=mock|supabase
VITE_AUTH MOCK_ROLE=super_admin
VITE_SUPABASE_URL / VITE_SUPABASE_ANON_KEY (public only)
.env.example (root) + apps/customer/.env.example updated
No secrets committed; service-role keys forbidden in public env
```

12. Future Supabase Integration Points

- Replace createSupabaseAuthProviderStub with real adapter using api-client
- Map profiles.roles / JWT claims -> AppRole[]
- Implement signInWithPassword / phone OTP on AuthProvider
- hydrateFromExternal(session) after supabase.auth.getSession()
- Keep MODULE_ALLOWED_ROLES as source of truth; sync with RLS policies
- Turn off mock autoSignIn; mount login screens in a later sprint
- Customer app can share parsePublicAuthConfig + SessionProvider gradually

13. Validation

Check	Result
pnpm --filter @groaurum/auth typecheck	Pass
pnpm --filter @groaurum/auth test	Pass
pnpm --filter @groaurum/admin-web typecheck	Pass
pnpm --filter @groaurum/admin-web build	Pass
Login screens	Not implemented (by design)
Live Supabase Auth	Stub only (by design)
New product screens / redesign	None

14. How to Review

```
pnpm install
pnpm dev:admin
# Default mock super_admin - full sidebar
# Set VITE_AUTH MOCK_ROLE=read_only in .env.local
# Confirm Settings route shows Forbidden; Settings nav hidden
# Set VITE_AUTH MOCK_ROLE=salesman - Wrong application foundation view
```

15. Intent

Sprint 2 establishes production-ready authentication and RBAC architecture so login UI and Supabase Auth can plug into stable contracts without rewriting modules or inventing per-app auth forks.